

Overview projeto Zurich

Resumo

A Zurich busca elevar a maturidade de **governança de acesso no SharePoint Online**, reduzindo **vazamento de informações e não conformidades (LGPD)**, especialmente em cenários de **movimentação interna** (Joiner/Mover/Leaver) onde **acessos indevidos persistem**.

A Foursys propõe um **produto SaaS multi-tenant** (não sob medida exclusiva), contratado pela Zurich, que:

- **Fase 1 – Discovery:** mapeia o cenário atual e constrói a **Base Autoritativa** (perfis/departamentos/dados sensíveis/regras de acesso).
- **Fase 2 – Plataforma:** executa “agentes”/motores automatizados que **cruzam permissões e logs do SharePoint** com a Base Autoritativa, operando em **modos evolutivos**:
 1. **Alertar Segurança**
 2. **Alertar + Educar Usuário**
 3. **Auto-remediar (Revogar)** com guard-rails
- **Fase 3 – Governança & Sustentação:** operação contínua, recertificações, indicadores de maturidade e paralelização dos “scans”.

A Zurich **prefere modelo de produto (SaaS da Foursys)**, para amortizar o investimento e potencial de **venda para outros clientes** no futuro.?

2) Principais Pontos

- **Problema:** acessos mantidos após mudança de área (ex.: ex-RH no Marketing com acesso a docs de RH).
- **Plataforma** com execuções **periódicas** (iniciar diário) e evolução para **near real-time**.
- **Base Autoritativa** como “fonte de verdade” para validação de acesso, sustentada por dados de RH/Org.
- **Três Fases**, com amadurecimento de resposta (alerta → educação → revogação).
- **POC anterior** validou ideias em **dataset artificial (CSV); integrações reais M365/Graph/SharePoint ainda não existem**.
- **Decisão do cliente:** **não** quer solução “sob medida” exclusiva; **quer um produto** (da Foursys) que atenda a necessidade e possa ser reutilizado.

3) Escopo e Objetivos

- **Escopo:** SharePoint Online (inclui bibliotecas de Teams que usam SPO), permissões, links, compartilhamentos internos/externos, logs M365.
- **Objetivos:**
 - **Detectar** acessos inconformes frente à Base Autoritativa.
 - **Notificar e educar** usuários e segurança.
 - **Remediar automaticamente** acessos indevidos com aprovação/rollback.
 - **Evidenciar compliance** (trilha, relatórios, KPIs).
 - **Evoluir para near real-time** onde tecnicamente suportado.
 - **SaaS multi-tenant** com isolamento por cliente, segurança forte e LGPD.

4) Premissas

1. **SharePoint Online** é o repositório alvo, com **Microsoft Entra ID** como IdP.
2. **Unified Audit Log** do M365 e auditoria do SharePoint estão (ou serão) habilitados, com **retenção adequada**.
3. **Integração com RH** (fonte autoritativa JML) estará disponível (API/arquivo/ETL), com atributos mínimos (matrícula/UPN, cargo, depto, gestor, data de movimento).
4. A plataforma começará **rule-based/policy-driven; heurísticas/ML** entram depois, com thresholds e A/B.
5. **Auto-remediação** (Modo 3) exige **guard-rails**: aprovações, escopos, janelas de execução e **rollback**.
6. **LGPD e residência de dados**: processamento e armazenamento primários em **região Brasil** (quando aplicável).
7. Modelo de **produto (SaaS)**: app **multi-tenant**; **dados segregados por cliente**; **BYOK** opcional.

Arquitetura de Solução (Azure/Microsoft 365) — SaaS Multi-tenant

6.1 Componentes (Elegíveis)

- **Microsoft 365 / SharePoint Online:** fonte de permissões, links, eventos.
- **Microsoft Entra ID (multi-tenant app):** autenticação/consent do cliente; **Access Reviews & Entitlement Management** (Governança nativa).
- **Microsoft Purview:**
 - **Sensitivity Labels** e **MIP** para reforço por conteúdo.
 - **DLP M365** para bloqueios preventivos de compartilhamento.
- **Logs/Streaming:**
 - **Unified Audit Log** via **Microsoft Sentinel (Office 365 connector)** como near real-time de auditoria.
 - **Graph change notifications** (webhooks) quando aplicável.
- **Ingestão & Processamento:**
 - **Azure Event Hub / Service Bus** para filas e DLQ.
 - **Azure Functions/Logic Apps** para orquestração e automação (alertas, remediações).
 - **Azure Databricks/Azure Synapse** para varreduras paralelas e análises batch.
 - **Azure Machine Learning** (futuro) para detecção de anomalias/UEBA.
- **Dados & Configuração:**
 - **Azure SQL** (ou **Cosmos DB**) para **Base Autoritativa**, políticas e estado.
 - **Azure Data Lake Gen2** para eventos, snapshots de permissões e evidências.
 - **Azure Key Vault** para segredos/chaves/certs.
- **Aplicação:**
 - **Azure App Service** (ou **AKS**) para o **Portal SaaS** (admin, relatórios, exceções).
 - **Power Apps/Power Automate** (opcional) para fluxos de aprovação simples.
- **Observabilidade & Segurança:**
 - **Microsoft Sentinel** (SIEM/SOAR) + **Azure Monitor / App Insights**.
 - **Private Endpoints** e **VNet Integration** onde aplicável.
 - **Managed Identities** para acesso seguro a recursos Azure.

5) Perguntas :

1. **Confirmar modelo:** SaaS Foursys? Hospedado onde (Foursys ou Zurich)?
2. **Objetivo , Criterio de Sucesso:** quais áreas **prioritárias**?(ex. redução do tempo de exposição, nº de acessos indevidos detectados, % revogações sem rollback).
3. **Base Autoritativa/JML:** fonte e **frequência**; atributos mínimos que teremos?
4. **Logs/near real-time:** UAL habilitado? Sentinel/Connector ativo? Expectativa de **latência**?
5. **Modos & guard-rails:** quando podemos **revogar automaticamente** e com quais **limites/janelas**?
6. **LGPD & residência:** precisa **Brasil, BYOK**, pseudonimização em relatórios?
7. **Métricas de sucesso:** quais **KPIs** vão para o comitê executivo (mensal)?
8. **SLA & operação:** quem recebe alertas; janela de operação; **rollback** desejado.
9. **Tarifação:** preferem **flat (por porte), capacidade** (site/evento), **ação** (remediação) ou **híbrido**?
10. **Cronograma:** janela para **Discovery, MVP** .